ZAP Report - BEFORE fix (IDOR & Mass Assignment) - IT22105820

College Management System backend at commit 3ea205e (develop before PR #10). Requests for students, faculty and admin were proxied through OWASP ZAP 2.16. Access-control and mass-assignment tests were performed manually with ZAP and recorded as alerts; ZAP's passive scanner also ran on all traffic.

Site: http://localhost:4000

Generated on Wed, 14 Oct 2026 13:47:32

ZAP Version: 2.16.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	4
Medium	3
Low	0
Informational	2
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
Broken Access Control (IDOR): student can modify another student's record	High	1
Mass Assignment: privilege escalation via isSuperAdmin / googleId / employeeId	High	1
Missing Authorization: student can change another student's marks	High	1
Missing Authorization: student can modify an admin account	High	1
Mass Assignment: MongoDB update operator injection ($unset deletes data)	Medium	1
Missing Authorization: faculty can perform admin-only action (create branch)	Medium	1
Missing Authorization: student can read every student's personal data	Medium	1
Authentication Request Identified	Informational	3
Session Management Response Identified	Informational	3

Alert Detail

High	Broken Access Control (IDOR): student can modify another student's record
Description	Manual test (T1) proxied through ZAP. The server accepted the request and returned HTTP 200. The API only checks that the caller is logged in; it never checks the caller's role or whether they own the object referenced by the ID.
URL	http://localhost:4000/api/student/6acf3a97b69ef65737b81d46
Method	PATCH
Attack	Logged in as student Alice, sent PATCH /api/student/6acf3a97b69ef65737b81d46 (Bob's ID) with {"firstName":"Hacked"}
Evidence	"firstName":"Hacked"
Other Info	Commit under test: 3ea205e (develop before PR #10)
Instances	1
Solution	Put the role in the signed JWT, verify the account on each request, and enforce roles per route with authorize(...roles). Read a student's own data from the token, not the URL.
Reference	https://owasp.org/Top10/A01_2021-Broken_Access_Control/ https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/ https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
CWE Id	639
WASC Id	2
Plugin Id	

High	Mass Assignment: privilege escalation via isSuperAdmin / googleId / employeeId
Description	Manual test (T6) proxied through ZAP. The server accepted the request and returned HTTP 200. The API copies every property from the JSON body into the database update, so a client can set server-managed fields or MongoDB operators.
URL	http://localhost:4000/api/admin/6acf3a96b69ef65737b81d3f
Method	PATCH
Attack	Logged in as a normal admin, sent PATCH /api/admin/<own id> with extra fields {"isSuperAdmin":true,"googleId":"attacker-google-sub","employeeId":1}
Evidence	"isSuperAdmin":true
Other Info	Commit under test: 3ea205e (develop before PR #10)
Instances	1
Solution	Copy only allowlisted fields with primitive values from the request body (pickFields / pickProfileFields).
Reference	https://owasp.org/Top10/A01_2021-Broken_Access_Control/ https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/ https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
CWE Id	915
WASC Id	20
Plugin Id	

High	Missing Authorization: student can change another student's marks
Description	Manual test (T2) proxied through ZAP. The server accepted the request and returned HTTP 200. The API only checks that the caller is logged in; it never checks the caller's role or whether they own the object referenced by the ID.
URL	http://localhost:4000/api/marks/bulk
Method	POST
Attack	Logged in as student Alice, sent POST /api/marks/bulk setting Bob's mark (was 78) to 0

Evidence	"marksObtained":0
Other Info	Commit under test: 3ea205e (develop before PR #10)
Instances	1
Solution	Put the role in the signed JWT, verify the account on each request, and enforce roles per route with authorize(...roles). Read a student's own data from the token, not the URL.
Reference	https://owasp.org/Top10/A01_2021-Broken_Access_Control/ https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/ https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
CWE Id	285
WASC Id	2
Plugin Id	

High	**Missing Authorization: student can modify an admin account**
Description	Manual test (T4) proxied through ZAP. The server accepted the request and returned HTTP 200. The API only checks that the caller is logged in; it never checks the caller's role or whether they own the object referenced by the ID.
URL	http://localhost:4000/api/admin/6acf3a96b69ef65737b81d3f
Method	PATCH
Attack	Logged in as student Alice, sent PATCH /api/admin/6acf3a96b69ef65737b81d3f with {"designation":"Pwned by student"}
Evidence	"designation":"Pwned by student"
Other Info	Commit under test: 3ea205e (develop before PR #10)
Instances	1
Solution	Put the role in the signed JWT, verify the account on each request, and enforce roles per route with authorize(...roles). Read a student's own data from the token, not the URL.
Reference	https://owasp.org/Top10/A01_2021-Broken_Access_Control/ https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/ https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
CWE Id	285
WASC Id	2
Plugin Id	

Medium	**Mass Assignment: MongoDB update operator injection ($unset deletes data)**
Description	Manual test (T7) proxied through ZAP. The server accepted the request and returned HTTP 200. The API copies every property from the JSON body into the database update, so a client can set server-managed fields or MongoDB operators.
URL	http://localhost:4000/api/branch/6acf3a96b69ef65737b81d3b
Method	PATCH
Attack	Sent PATCH /api/branch/<id> with body {"$unset":{"name":1}}
Evidence	"branchId":"IT"
Other Info	Commit under test: 3ea205e (develop before PR #10)
Instances	1
Solution	Copy only allowlisted fields with primitive values from the request body (pickFields / pickProfileFields).
Reference	https://owasp.org/Top10/A01_2021-Broken_Access_Control/ https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/ https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html

CWE Id	915
WASC Id	20
Plugin Id	

Medium	Missing Authorization: faculty can perform admin-only action (create branch)
Description	Manual test (T5) proxied through ZAP. The server accepted the request and returned HTTP 201. The API only checks that the caller is logged in; it never checks the caller's role or whether they own the object referenced by the ID.
URL	http://localhost:4000/api/branch
Method	POST
Attack	Logged in as faculty Kamal, sent POST /api/branch
Evidence	"branchId":"FAKE"
Other Info	Commit under test: 3ea205e (develop before PR #10)
Instances	1
Solution	Put the role in the signed JWT, verify the account on each request, and enforce roles per route with authorize(...roles). Read a student's own data from the token, not the URL.
Reference	https://owasp.org/Top10/A01_2021-Broken_Access_Control/ https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/ https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
CWE Id	285
WASC Id	2
Plugin Id	

Medium	Missing Authorization: student can read every student's personal data
Description	Manual test (T3) proxied through ZAP. The server accepted the request and returned HTTP 200. The API only checks that the caller is logged in; it never checks the caller's role or whether they own the object referenced by the ID.
URL	http://localhost:4000/api/student
Method	GET
Attack	Logged in as student Alice, sent GET /api/student (admin-only list)
Evidence	"email":"bob@college.lk"
Other Info	Commit under test: 3ea205e (develop before PR #10)
Instances	1
Solution	Put the role in the signed JWT, verify the account on each request, and enforce roles per route with authorize(...roles). Read a student's own data from the token, not the URL.
Reference	https://owasp.org/Top10/A01_2021-Broken_Access_Control/ https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/ https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
CWE Id	285
WASC Id	2
Plugin Id	

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://localhost:4000/api/admin/login

Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=admin@college.lk passwordParam=password
URL	http://localhost:4000/api/faculty/login
Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=faculty@college.lk passwordParam=password
URL	http://localhost:4000/api/student/login
Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=alice@college.lk passwordParam=password
Instances	3
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	**Session Management Response Identified**
Description	The given response has been identified as containing a session management token. The 'Other tokens that can be used in the Header Based Session Management Method. If the request is in Management Method set to "Auto-Detect" then this rule will change the session management to
URL	http://localhost:4000/api/admin/login
Method	POST
Attack	
Evidence	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9. eyJ1c2VySWQiOiI2YWNmM2E5NmI2OWVmNjU3MzdiODFkM2YiLCJpYXQiOjE3OTE5NjU4ND XfbN9tMx-vjqTbsA6MVZKd2QeR9Qsf220ZlQHhJdwO0
Other Info	json:data.token
URL	http://localhost:4000/api/faculty/login
Method	POST
Attack	
Evidence	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9. eyJ1c2VySWQiOiI2YWNmM2E5N2I2OWVmNjU3MzdiODFkNDIiLCJpYXQiOjE3OTE5NjU4NDk eGQn7mxCQ6VZdn1ryErdIA1s89fQFd8xHGyT5faZsXU
Other Info	json:data.token
URL	http://localhost:4000/api/student/login
Method	POST

Attack	
Evidence	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9. eyJ1c2VySWQiOiI2YWNmM2E5N2I2OWVmNjU3MzdiODFkNDQiLCJpYXQiOjE3OTE5NjU4ND EqrOlgps39R6eUCwZ36A6c3kprqv1E6njaMID-xGkow
Other Info	json:data.token
Instances	3
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id
CWE Id	
WASC Id	
Plugin Id	10112